

Incident Report: SOAR-0006

AICS-112 Lab 7 capstone | Pipeline v1.1.0, playbook v1.1.0 | Prepared by Firdaws Alnuur Mohammed |
All data synthetic; all actions dry-run

Executive summary

A finance-operations user, fatima.sani, received a phishing email on 26 August 2026 and within about 50 minutes her account was taken over from Ghana, an unverified OAuth app was granted mailbox access, her workstation OPS-WS-009 ran encoded PowerShell and beacons out, and 96 MB left the network to flagged infrastructure. The pipeline scored this 97/100 (critical).

Status: contained in simulation only. Three high-impact actions are waiting for a named human approver: isolate OPS-WS-009, disable the identity and revoke the OAuth grant. Decision required: approve all three, then reset credentials and review what the 96 MB contained.

Scope and confidence

- Users: fatima.sani. Asset: OPS-WS-009. Window: 06:58 to 07:48 UTC (07:58 to 08:48 WAT) on 2026-08-26.
- Sources: email, proxy, identity, endpoint, network (5 of 5 relevant sources, 9 correlated events).
- Confidence: high that this is a real compromise, because five independent sources agree and two indicators match threat intel. Medium on what was exfiltrated: we know the size and destination, not the content.
- Gaps: no mailbox audit log (what MailSync Pro read), no proxy content inspection, and the capstone has no ground truth, so no precision or recall can be claimed.

Timeline

Times are UTC / WAT (UTC+1). Event IDs are from the capstone dataset.

UTC / WAT	Event	Observation	Interpretation	Action
06:58 / 07:58	CP-001	Remittance notice delivered from external sender (secure-docs-auth.example)	Likely phishing lure; domain matches threat intel	Case opened
07:02 / 08:02	CP-002	User clicked the external authentication link	Credential-harvest page visited	Case opened
07:09 / 08:09	CP-003	Sign-in failure from 198.51.100.44 (GH)	Attacker testing stolen credentials	Analyst notified
07:11 / 08:11	CP-004	Sign-in success from GH; user normally signs in from NG	Account takeover (impossible-geography login)	Analyst notified
07:16 / 08:16	CP-005	Consent granted to unverified app "MailSync Pro"	Persistence through OAuth grant; survives a password reset	revoke_oauth_grant planned (approval)
07:31 / 08:31	CP-006	Encoded PowerShell launched from a spreadsheet process on OPS-WS-009	Malicious macro execution; payload hash matches threat intel	isolate_endpoint planned (approval)
07:34 / 08:34	CP-007	TLS beacon every 60 s to 203.0.113.77	Command-and-control channel	Triage collected
07:41 / 08:41	CP-008	Browser credential store access attempt, blocked	Credential theft attempt stopped by endpoint control	None needed
07:48 / 08:48	CP-009	96 MB upload to 203.0.113.77, allowed	Probable data exfiltration	disable_identity planned (approval)

Technical findings

- IOC matches: IP 198.51.100.44, domain secure-docs-auth.example and the PowerShell file hash 9d6f8f67... are inside their STIX valid_from/valid_until windows at event time (the v1.1.0 validity check).
- Score drivers (model probability 0.997): ioc_match, multi_source, malware_signal, identity_anomaly, exfil_signal. critical_asset and privileged_identity were 0, so the score comes from the attack chain, not from who the user is.
- Shared infrastructure: the same IP 198.51.100.44 was used in the password spray against wale.admin (SOAR-0005). The pipeline did not link the two incidents. This is probably one campaign and is the main correlation gap.
- AI assist: advisory only. The summary quotes the factors above and cites no unsupported claims; no prompt-injection flags were raised on this incident.

ATT&CK mapping

Technique	Evidence	Uncertainty
T1566 Phishing	CP-001, CP-002	Link vs attachment delivery not confirmed
T1078 Valid Accounts	CP-003, CP-004	Credentials were presumably phished; not directly observed
T1528 Steal Application Access Token (OAuth abuse)	CP-005	Scope of permissions granted is unknown
T1059.001 PowerShell	CP-006	Macro origin inferred from parent process
T1071 Application Layer Protocol (C2)	CP-007	Beacon interval is strong evidence; payload unseen
T1555 Credentials from Web Browsers	CP-008	Blocked, so no confirmed theft
T1041 Exfiltration Over C2 Channel	CP-009	Content of the 96 MB unknown

Containment and approval

- Automatic, no approval: create_case, notify_analyst, collect_endpoint_triage (all dry-run).
- Approval-gated and awaiting_approval: isolate_endpoint (endpoint evidence present), disable_identity (score 85 or above), revoke_oauth_grant (oauth_consent event present).
- Approver and result: to be recorded from the browser console. Replace this line with the approver name, time and decision before submission.
- Every action ran with dry_run on; no real account or endpoint was changed. The audit hash chain verified OK.

Eradication and recovery

- After approval: isolate OPS-WS-009, disable fatima.sani, revoke MailSync Pro, reset the password and all sessions, and re-enroll MFA.
- Block 198.51.100.44, 203.0.113.77 and secure-docs-auth.example; search mail for other recipients of the lure.
- Reimage the workstation, then validate: no beacon for 24 hours, no new OAuth grants, clean sign-in history.

- Rollback: re-enable the account and release the host from isolation if the investigation shows a false positive.

Data-protection considerations

Personal data involved: one employee identity, her sign-in locations and mailbox access. The exfiltrated 96 MB may contain customer or personnel data, so the DPO and legal should be told now, since a notification clock may be running. Evidence access is limited to the case team; retain logs under the incident-retention policy.

Lessons and backlog

- Link incidents that share an attacker IP (SOAR-0005 and SOAR-0006). New backlog item.
- Make the 30-minute approval expiry real (S2) and log model name and prompt hash for AI calls (G2).
- Keep the benign-context rule. In SOAR-0009 a blocked and quarantined attachment fell from 83 to 68, and in SOAR-0005 an approved change no longer triggers isolation.
- Trade-off to defend: SOAR-0005 stays critical (91) because a privileged admin account was sprayed from a known-bad IP, even though the lockout held.